

Nachmittag 1 – Govern & Grundlagen

Erste Standortbestimmung

Selbsteinschätzung des Cybersecurity-Reifegrads mit dem NIST CSF 2.0

Dauer	45–60 Minuten (inkl. 15 Min. Ergebnisdiskussion im Plenum)
Arbeitsform	Gruppen à 3–4 Personen
Material	Dieses Arbeitsblatt, Stifte; optional Flipchart für die Ergebnispräsentation
NIST-CSF-Bezug	Alle 6 Funktionen; vertieft: Govern (GV.OC, GV.RM, GV.RR, GV.PO)

Lernziele

- Die sechs Funktionen des NIST CSF 2.0 auf ein konkretes KMU anwenden können.
- Den aktuellen Reifegrad eines Unternehmens strukturiert und begründet einschätzen.
- Verantwortlichkeiten für Cybersecurity benennen und Lücken in der Governance erkennen.
- Die drei wichtigsten Handlungsfelder ableiten und priorisieren.

Ausgangslage

Fallstudie: Muster Metallbau AG (fiktives KMU, 45 Mitarbeitende)

Dieses fiktive Unternehmen begleitet Sie durch alle sechs Übungen des Workshops.

- Branche & Tätigkeit: Metallbau und Montage – Fertigung in eigener Werkhalle plus Projektgeschäft bei Kunden vor Ort. Zusätzlich kleiner Webshop für Ersatzteile (extern gehostet).
- Mitarbeitende: 45 (30 Produktion/Montage, 15 Büro: Verkauf, Einkauf, Buchhaltung, Planung/CAD, Geschäftsleitung). Keine eigene IT-Stelle.
- IT-Landschaft: Microsoft 365 (E-Mail, Teams, SharePoint), lokales ERP-System (Aufträge, Lager, Fakturierung), 4 CAD-Arbeitsplätze, Dateiserver im Serverraum, ca. 20 Notebooks/PCs, 10 Firmen-Smartphones, WLAN für Büro und Werkhalle (ein gemeinsames Netz).
- IT-Betreuung: externer IT-Dienstleister „TechPartner GmbH“ mit Pauschalvertrag (8 Stunden/Monat, Reaktionszeit „best effort“).
- Sicherheits-Ausgangslage: keine dokumentierten Richtlinien, kein MFA, alle Büro-Nutzer sind lokale Administratoren, Backup läuft nachts auf ein NAS im selben Serverraum (kein Restore-Test bekannt), Patching „wenn Zeit ist“.
- Vorfall im letzten Jahr: gefälschte E-Mail im Namen des Geschäftsführers („CEO-Fraud“) – eine Zahlung über CHF 40 000 wurde in letzter Minute gestoppt.
- Kunden & Verträge: zwei Grosskunden verlangen neu einen Nachweis „angemessener Cybersicherheitsmassnahmen“ als Bedingung für die Vertragsverlängerung.

Aufgabe A – Wer ist eigentlich verantwortlich? (ca. 10 Min.)

Diskutieren Sie in der Gruppe und tragen Sie ein, wer bei der Muster Metallbau AG heute faktisch für die folgenden Aufgaben zuständig ist – und wer es sein sollte. Nutzen Sie: GL (Geschäftsleitung), BÜ (Mitarbeitende Büro), TP (TechPartner GmbH, externer IT-Dienstleister), NN (niemand).

Aufgabe	Heute zuständig	Sollte zuständig sein	Bemerkung
Cybersecurity-Strategie und Budget festlegen			
Richtlinien erlassen (z. B. Passwörter, private Nutzung)			
Benutzerkonten anlegen/entfernen (Ein-/Austritte)			
Backups überwachen und Restore testen			
Sicherheitsvorfälle melden und behandeln			
Einhaltung der Kundenanforderungen nachweisen			

Leitfrage: Kann die Verantwortung für Cybersecurity vollständig an den IT-Dienstleister ausgelagert werden? Notieren Sie Ihre Antwort in einem Satz.

Aufgabe B – Reifegrad-Selbsteinschätzung (ca. 25 Min.)

Bewerten Sie die Muster Metallbau AG je CSF-Funktion auf der Stufe 1–4. Stützen Sie sich ausschliesslich auf den Steckbrief; wo Informationen fehlen, treffen Sie eine begründete Annahme und notieren Sie diese.

Bewertungsstufen (angelehnt an die CSF-Tiers)

Stufe	Beschreibung
1 – Ad hoc / Partial	Nichts geregelt; Reaktionen erfolgen spontan und personenabhängig. Kein Bewusstsein auf Führungsebene.
2 – Risikoinformiert	Erste Massnahmen und Bewusstsein vorhanden, aber nicht dokumentiert, nicht einheitlich, stark personenabhängig.
3 – Wiederholbar / Repeatable	Dokumentierte, gelebte und regelmässig überprüfte Praxis; Verantwortlichkeiten klar zugewiesen.
4 – Adaptiv	Kontinuierliche Verbesserung auf Basis von Erfahrungen und Kennzahlen; Sicherheit ist Teil der Unternehmenskultur.

Einschätzung

Funktion	Leitfragen	Stufe (1–4)	Begründung / Beobachtung aus dem Steckbrief
Govern (GV)	Gibt es eine Cybersecurity-Strategie? Sind Rollen und Verantwortlichkeiten festgelegt? Existieren schriftliche Richtlinien? Befasst sich die Geschäftsleitung regelmässig mit dem Thema?		
Identify (ID)	Wissen wir, welche Systeme, Daten und Prozesse wir haben und wie kritisch sie sind? Wurden Risiken je systematisch bewertet? Kennen wir unsere Abhängigkeiten von Lieferanten?		
Protect (PR)	Gibt es MFA, geregelte Zugriffsrechte, Backups, Patching, Verschlüsselung? Werden Mitarbeitende geschult?		
Detect (DE)	Würden wir einen Angriff bemerken? Werden Logs gesammelt und angeschaut? Gibt es Alarme (z. B. bei verdächtigen Logins)?		
Respond (RS)	Gibt es einen Notfallplan? Weiss jeder, wen er bei einem Vorfall anruft? Wurden Vorfälle je geübt oder sauber dokumentiert?		

Funktion	Leitfragen	Stufe (1–4)	Begründung / Beobachtung aus dem Steckbrief
Recover (RC)	Könnten wir nach einem Totalausfall wiederherstellen? Wurde ein Restore je getestet? Gibt es eine Reihenfolge für den Wiederanlauf?		

Aufgabe C – Top-3-Handlungsfelder (ca. 10 Min.)

Leiten Sie aus Ihrer Einschätzung die drei wichtigsten Handlungsfelder ab. Formulieren Sie jedes als konkreten Auftrag an die Geschäftsleitung (nicht als Technik-Detail).

Nr.	Handlungsfeld (als Auftrag formuliert)	Betroffene CSF-Funktion(en)
1		
2		
3		

Diskussionsfragen fürs Plenum

- Bei welcher Funktion gingen die Einschätzungen in Ihrer Gruppe am weitesten auseinander – und warum?
- Was davon trifft auch auf Ihr eigenes Unternehmen zu?
- Warum beginnt das CSF 2.0 mit „Govern“ und nicht mit Technik?